

Mapeo de Objetivos y Métricas GQM a Requisitos Normativos

Este documento complementa el marco GQM+PRAGMATIC mapeando objetivos (G) y métricas (M) clave a los principales marcos normativos aplicables (NIS2, DORA, ENS, ISO 27001/27002, NIST CSF).

Tabla de mapeo QGM-Normativa

Objetivo/ Métrica	Descripción breve	NIS2	DORA	ENS	ISO 27001/2700 2	NIST CSF
G1	Cobertura de modelado de amenazas en sistemas críticos	Art. 21 (medidas técnicas)	Art. 8, 11 (gestión de riesgos TIC)	Análisis y gestión de riesgos	A.6, A.8, A.12	ID.RA-1, ID.RA-3
G1.M1	% de sistemas críticos con modelo de amenazas vigente	Art. 21	Art. 8, 11	Medidas de análisis y protección	A.14 (seguridad en desarrollo)	PR.IP-3, PR.IP-8
G1.M2	Frecuencia media de revisión de modelos	Art. 21, 23	Art. 11	Revisión periódica de medidas	Cl. 9 (evaluación)	ID.RA-3
G1.M3	% de proyectos con modelado en SDLC/CI-CD	Art. 21	Art. 8, 11	Integración en ciclo de vida	A.14 (desarrollo seguro)	PR.IP-3, PR.IP-8
G1.M4	Índice de participación multidisciplinar	Art. 21, 24	Art. 5, 6	Organización y responsabilidades	A.5 (organización interna)	ID.GV-1, PR.AT-3
G2	Reducción de vulnerabilidades explotadas activamente	Art. 21, 23	Art. 8, 11	Medidas técnicas y de prevención	A.12, A.13	PR.IP-12, DE.CM-8
G2.M1	% de vulnerabilidades explotadas activamente abiertas	Art. 21, 23	Art. 8, 11	Gestión de vulnerabilidades	A.12, A.13	PR.IP-12, DE.CM-8

G2.M2	% de vulnerabilidades explotadas con >12 meses de antigüedad	Art. 21, 23	Art. 8, 11	Mejora continua en parches	A.12, A.13	PR.IP-12
G2.M3	Tiempo medio de remediación de vulnerabilidades críticas	Art. 21, 23	Art. 8, 11	Criterios de seguridad de sistemas	A.12, A.13	PR.IP-12, RS.MI-1
G3	Reducción de tiempos de detección, contención y recuperación	Art. 23, 24	Art. 11, 15	Gestión de incidentes y continuidad	A.16, A.17	DE.CM-1, RS.RP-1, RC.IM-1
G3.M1	MTTD de incidentes significativos	Art. 23, 24	Art. 11	Monitorización y detección	A.16	DE.CM-1
G3.M2	MTTC de incidentes significativos	Art. 23, 24	Art. 11	Respuesta a incidentes	A.16	RS.RP-1
G3.M3	MTTR de servicios esenciales tras incidentes	Art. 21, 23, 24	Art. 11, 15	Continuidad y recuperación	A.17	RC.IM-1, RC.RP-1
G4	Uso de cuantificación económica del riesgo	Art. 21	Art. 6, 11	Análisis de riesgos	Cl. 6, Cl. 8	ID.RM-1, ID.RM-2
G4.M1	% de organizaciones con modelos económicos de riesgo	Art. 21	Art. 6, 11	Evaluación de riesgos	Cl. 6, Cl. 8	ID.RM-1

G4.M2	Frecuencia de reporting de métricas económicas al Consejo	Art. 20, 21	Art. 5, 6	Responsabilidad de la dirección	Cl. 5 (liderazgo)	ID.GV-1, ID.GV-3
G4.M3	% de decisiones de inversión que citan modelos de riesgo	Art. 20, 21	Art. 5, 6	Integración de riesgos en decisiones	Cl. 6, Cl. 7	ID.RM-1, ID.GV-3
G5	Reforzar seguridad en cadena de suministro y terceros	Art. 21, 23, 28	Art. 28	Relaciones con terceros	A.15	ID.SC-3, PR.AT-3
G5.M1	% de proveedores críticos evaluados en ciber	Art. 21, 23, 28	Art. 28	Evaluación de terceros	A.15	ID.SC-3
G5.M2	Frecuencia de revisión de riesgos de terceros	Art. 21, 23, 28	Art. 28	Seguimiento continuo de terceros	A.15	ID.SC-3
G5.M3	% de incidentes significativos atribuibles a terceros	Art. 23, 30	Art. 19, 28	Notificación y análisis de incidentes	A.16	RS.CO-1, ID.RA-1
G6	Talento, cultura y colaboración	Art. 20, 21	Art. 5, 6	Recursos y concienciación	A.6, A.7	PR.AT-1, PR.AT-2, ID.BE-4
G6.M1	Índice de suficiencia de recursos internos	Art. 20, 21	Art. 5, 6	Recursos humanos de seguridad	A.6, A.7	ID.GV-2, PR.AT-4
G6.M2	% de organizaciones con dificultades para cubrir vacantes	Art. 20	Art. 5	Recursos y planificación	A.6, A.7	ID.GV-2, PR.AT-4

G6.M3	% de empleados cubiertos por concienciación anual	Art. 21	Art. 6	Concienciación y formación	A.6, A.7	PR.AT-1, PR.AT-2
G6.M4	% de organizaciones que participan en foros/CSIRTs	Art. 21, 23	Art. 4, 6	Cooperación y coordinación	Cl. 4, Cl. 7	ID.BE-4, RS.CO-3

Este mapeo permite demostrar cómo cada métrica contribuye al cumplimiento de requisitos concretos y facilita su defensa ante auditores y reguladores.